CLOUDSHIELD TECHNOLOGIES

Vulnerability Management & Remediation Standard

Independent GRC Portfolio Project: Simulated Organization

Document Owner	Application / Security Engineering
Version	1.0
Effective Date	October 6, 2026
Review Cycle	At least annually and after material changes to vulnerability-management processes
Linked Portfolio Risk	GRC-003: Overdue Production Vulnerability / No Remediation SLA
Primary Treatment	Mitigate

1. Purpose

This standard defines CloudShield Technologies' minimum requirements for identifying, assessing, prioritizing, remediating, documenting, and escalating security vulnerabilities. It establishes risk-based remediation timelines so that material weaknesses do not remain unresolved without accountable action or formally approved risk treatment.

2. Scope

This standard applies to CloudShield-managed production and corporate technology, including cloud infrastructure, internet-facing applications, APIs, operating systems, databases, containers, endpoints, code dependencies, and other technology assets for which CloudShield is responsible.

3. Roles and Responsibilities

Role	Responsibility
Security	Define severity and remediation requirements; validate findings; monitor overdue vulnerabilities; review exceptions and risk acceptance.
Asset / System Owner	Confirm asset criticality, support prioritization, assign remediation resources, and ensure timely closure.
Engineering / IT	Investigate, patch, upgrade, configure, mitigate, test, and document remediation.
Risk Approver	Approve time-limited exceptions when remediation cannot meet the required timeline and residual risk is understood.
Management	Support escalation and resource decisions for material or repeatedly overdue risk.

4. Vulnerability Identification

- CloudShield will use appropriate vulnerability scanning, security testing, vendor advisories, penetration testing, dependency/code analysis, and other relevant sources to identify vulnerabilities.
- Internet-facing and production assets must be included in an authorized vulnerability-management process.
- Findings must be traceable to an affected asset, owner, severity, discovery date, remediation status, and evidence of closure.
- Duplicate or false-positive findings may be closed only with documented validation.

5. Severity & Remediation Requirements

Severity is determined using technical severity together with business context such as exploitability, exposure, asset criticality, data sensitivity, compensating controls, and credible threat information. The following are CloudShield's maximum target remediation timelines for this simulated standard:

Severity	Target Remediation	Example Risk Context	Escalation	Exception Required if Overdue
Critical	24 hours	Actively exploitable or severe exposure affecting critical/internet-facing systems.	Immediate Security + system owner + management	Yes
High	7 calendar days	Serious weakness with meaningful likelihood/impact, particularly on production or sensitive systems.	Security + system owner	Yes

Severity	Target Remediation	Example Risk Context	Escalation	Exception Required if Overdue
Medium	30 calendar days	Material weakness with lower urgency or meaningful mitigating factors.	System owner; Security tracks aging	Yes if deadline cannot be met
Low	90 calendar days	Limited-risk weakness with low exposure or impact.	System owner	Risk-based extension may be documented

6. Remediation Workflow

- Validate the vulnerability and identify the affected asset, owner, exposure, and business context.
- Assign severity and create a remediation record/ticket with the discovery date and required due date.
- Select a treatment: patch, upgrade, configuration change, code fix, service removal, isolation, compensating control, or other approved remediation.
- Test the proposed remediation when practical before production deployment.
- Implement the remediation within the applicable target timeline.
- Retest or otherwise verify closure and retain evidence.
- Close the finding only after the remediation result is documented and accepted by the responsible process.

7. Exceptions and Risk Acceptance

When a vulnerability cannot be remediated within the target timeline, the responsible owner must request a documented, time-limited exception before the deadline whenever practical. An exception does not erase the vulnerability; it documents why the residual risk is temporarily accepted and how it will be controlled.

Required Exception Element	Minimum Requirement
Business justification	Why the required remediation cannot be completed on time.
Risk statement	Affected asset, vulnerability, exposure, likelihood/impact considerations, and potential business consequence.
Compensating controls	Temporary safeguards that reduce likelihood or impact.
Accountable owner	Named person/function responsible for the residual risk and remediation.
Approval	Authorized risk approver appropriate to the severity and business impact.
Expiration date	A defined date after which the exception must be renewed or the vulnerability remediated.
Remediation plan	Specific corrective action and target completion date.

8. Compensating Controls

Compensating controls may reduce exposure while permanent remediation is pending, but they must not be used indefinitely to avoid remediation. Depending on the vulnerability, examples may include:

- Network segmentation, firewall/WAF restrictions, or removal of public exposure.
- Disabling the vulnerable feature or service.
- Enhanced monitoring, alerting, or logging.
- Temporary access restrictions or additional authentication requirements.
- Application-layer protections or configuration changes.
- Other controls supported by documented technical analysis.

9. Overdue Vulnerability Escalation

- Critical vulnerabilities that exceed the 24-hour target require immediate documented escalation and an approved exception/risk decision.
- High vulnerabilities that exceed seven calendar days require escalation to Security and the accountable system owner, with documented treatment and management visibility as appropriate.
- Repeated overdue findings may trigger a broader control finding, management action plan, or review of staffing/process deficiencies.
- Open vulnerabilities must remain visible in tracking and reporting until verified closed or formally accepted for a defined period.

10. Verification & Closure Evidence

- Closure evidence should demonstrate that the vulnerable condition is no longer present or that the approved treatment is operating as intended.
- Evidence may include a clean rescan, patch/version record, configuration evidence, code/deployment reference, penetration-test retest, or other technically appropriate proof.
- The remediation record must preserve the original finding, action taken, completion date, verifier, and supporting evidence.

11. Metrics and Reporting

Metric	Purpose
Open vulnerabilities by severity	Shows current risk exposure.
Overdue vulnerabilities by severity/owner	Highlights remediation failures and accountability.
Mean/median time to remediate	Measures remediation performance.
Exception count and aging	Shows reliance on temporary risk acceptance.
Repeat/reopened findings	Identifies ineffective remediation or recurring root causes.
Critical/High SLA compliance	Measures adherence to the 24-hour and 7-day targets.

12. Application to GRC-003

Assessment Element	CloudShield GRC-003 Application
Finding	High-severity vulnerability on an internet-facing customer application remained unresolved for 47 days.
Control Gap	CloudShield had vulnerability scanning but no formal severity-based remediation SLA.
Required Timeline	High = 7 calendar days under this standard.
Status at Assessment	Overdue by 40 days relative to the new target.
Required Action	Remediate immediately or obtain a documented, time-limited exception with compensating controls and accountable approval.
Risk Treatment	Mitigate.
Verification	Retest the affected application and retain closure evidence.
Management Lesson	Detection alone is insufficient; vulnerability management requires ownership, timelines, escalation, evidence, and risk decisions.

13. Standard Review and Enforcement

Security will review this standard at least annually and after material changes to CloudShield's technology environment, threat landscape, or vulnerability-management process. Failure to follow the standard may be escalated to the responsible manager and may result in additional risk treatment, compensating controls, or management action.

Appendix A: Vulnerability Exception Record

Field	Record

Field	Record
Vulnerability / Finding ID	
Affected Asset / Service	
Severity	
Discovery Date	
Original Due Date	
Reason Remediation Cannot Meet SLA	
Risk Statement	
Compensating Controls	
Remediation Plan	
Accountable Owner	
Approver	
Exception Expiration	
Final Remediation Date	
Closure / Retest Evidence	